

Internal Security Audit Botium Toys

This audit was done by Said Al Harthy.

Activity overview

I conducted a comprehensive internal security audit for Botium Toys, a simulated small U.S. business specializing in toys. The audit aimed to assess their current security posture, identify vulnerabilities, and ensure compliance with relevant industry standards and regulations. This project allowed me to apply foundational cybersecurity concepts, including control assessment, risk identification, and compliance evaluation.

Scope and goals of the audit

Scope: *The scope is defined as the entire security program at Botium Toys. This means all assets need to be assessed alongside internal processes and procedures related to the implementation of controls and compliance best practices.*

Goals: *Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture.*

Current assets

Assets managed by the IT Department include:

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Risk assessment

Risk description

Currently, there is inadequate management of assets. Additionally, Botium Toys does not have all of the proper controls in place and may not be fully compliant with U.S. and international regulations and standards.

Control best practices

The first of the five functions of the NIST CSF is Identify. Botium Toys will need to dedicate resources to identify assets so they can appropriately manage them. Additionally, they will need to classify existing assets and determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1 to 10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to compliance best practices.

Additional comments

The potential impact from the loss of an asset is rated as medium, because the IT department does not know which assets would be at risk. The risk to assets or fines from governing bodies is high because Botium Toys does not have all of the necessary controls in place and is not fully adhering to best practices related to compliance regulations that keep critical data private/secure. Review the following bullet points for specific details:

- Currently, all Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
- Encryption is not currently used to ensure confidentiality of customers' credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
- Access controls pertaining to least privilege and separation of duties have not been implemented.
- The IT department has ensured availability and integrated controls to ensure data integrity.
- The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
- Antivirus software is installed and monitored regularly by the IT department.
- The IT department has not installed an intrusion detection system (IDS).
- There are no disaster recovery plans currently in place, and the company does not have backups of critical data.
- The IT department has established a plan to notify E.U. customers within 72

hours if there is a security breach. Additionally, privacy policies, procedures, and processes have been developed and are enforced among IT department members/other employees, to properly document and maintain data.

- Although a password policy exists, its requirements are nominal and not in line with current minimum password complexity requirements (e.g., at least eight characters, a combination of letters and at least one number; special characters).
- There is no centralized password management system that enforces the password policy's minimum requirements, which sometimes affects productivity when employees/vendors submit a ticket to the IT department to recover or reset a password.
- While legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear.
- The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks, up-to-date closed-circuit television (CCTV) surveillance, as well as functioning fire detection and prevention systems.

Controls Assessment Checklist

Control	In Place?	Explanation
Least Privilege	No	All employees can access sensitive internal data. No access restrictions implemented.
Disaster Recovery Plans	No	No plans or backups exist for data recovery after incidents.
Password Policies	No	Password policy is outdated and does not meet complexity standards.
Separation of Duties	No	Roles and duties are not separated, increasing risk of abuse.
Firewall	Yes	A firewall is in place with defined rules to block unauthorized traffic.
Intrusion Detection System (IDS)	No	No IDS has been installed to detect anomalous activity.
Backups	No	Critical data is not backed up, risking loss during incidents.
Antivirus Software	Yes	Antivirus is installed and regularly monitored.
Manual Legacy System Monitoring	No	Legacy systems are monitored manually without a fixed schedule for these tasks.
Encryption	No	No encryption used for sensitive customer or payment data.
Password Management System	No	No centralized system; password resets handled manually.
Locks (Physical Security)	Yes	Locks in place for office, storefront, and warehouse.
CCTV Surveillance	Yes	Surveillance system is operational and up to date.
Fire Detection/Prevention	Yes	Fire alarms and sprinklers are functional.

GDPR Compliance Checklist

GDPR Best Practice	In Place?	Explanation
E.U. customers' data is kept private/secured.	No	As per risk assessment report data is not kept private/secured
Notify E.U. customers within 72 hours of breach.	Yes	Company has breach notification plan in line with GDPR.
Data is properly classified and inventoried.	No	Assets not classified so risk remains high.
Enforce privacy policies and procedures.	No	They do not have all of the necessary controls in place

System and Organization Controls (SOC) Checklist

SOC Best Practice	In Place?	Explanation
User access policies are established.	No	No role-based access or least privilege policy implemented.
Sensitive data (PII/SPII) is private.	No	No encryption or restriction on sensitive data access, PII/SPII is not confidential
Data integrity ensured.	No	Controls in place to ensure data consistency and integrity.
Data available to authorized users.	No	Data is available to almost all internal employees

Recommendations:

After completing the audit for Botium Toys, it's clear that there are some serious security gaps that need to be addressed. The current environment leaves the company vulnerable to data breaches, operational downtime, and non-compliance with major standards like **PCI DSS**, **GDPR**, and **SOC 2**. Below are my top recommendations to improve security and reduce risk across the organization.

1. Limit Access – Least Privilege & Separation of Duties

Right now, everyone has access to almost everything, including customer data which is a huge risk.

- **Access must be limited** based on each employee's actual job role. This follows the **least privilege** principle and helps prevent mistakes or misuse.

- **Important tasks should be split** between different people (**separation of duties**) so no one person has too much control.

These are basic but powerful controls that reduce insider threats and support compliance with PCI DSS and SOC requirements.

2. Encrypt Sensitive Information (Especially Credit Card Data)

Customer credit card information isn't encrypted at all which is a serious problem.

- Botium Toys **must start encrypting** all sensitive data, including credit card details and personal information (like names, emails, etc.).
- Encryption **should be applied during storage and transmission** using modern standards like **AES-256** and **TLS 1.2+**.

Not encrypting this data puts the company at risk of data breaches and major fines especially under PCI DSS.

3. 🗄️ Create a Backup and Disaster Recovery Plan

There's currently no backup system or recovery plan in place. If something went wrong like a cyberattack or system failure the company could lose everything.

- A solid **disaster recovery plan must be created** and tested regularly.
- **Backups should be automated**, stored securely, and tested to make sure they actually work when needed.

This isn't just about compliance — it's about protecting the business from permanent damage.

4. Improve Password Security

The current password policy is way too basic, and without a management system, it's hard for users to keep up.

- Botium Toys **should implement a stronger password policy**, including complexity (uppercase, lowercase, symbols, numbers, etc.) and expiration rules.
- A **password manager must be deployed** to make it easier for staff to follow good password hygiene and reduce help desk tickets.

This one change could help block a lot of low-effort attacks like brute-force or phishing-based login attempts.

5. Install an Intrusion Detection System (IDS)

There's no way for the IT team to know if something unusual is happening on the network.

- An **IDS must be installed** to monitor traffic and detect suspicious activity.
- It should alert the right people immediately if something looks wrong — like malware behavior or unauthorized access attempts.

This is a key step for early threat detection and is expected under most modern security frameworks.

6. Fix Compliance Gaps (PCI DSS & GDPR)

Many of the issues I found — like open access, weak passwords, and lack of encryption — also put the company out of compliance.

- For **PCI DSS**, credit card handling must be secured, encrypted, and access-restricted.
- For **GDPR**, all personal data needs to be classified, inventoried, and managed properly — especially for customers in the EU.

Botium Toys should **make compliance a priority**, not just to avoid fines, but to earn customer trust.

Final Thoughts

This audit showed that Botium Toys is currently at a high level of risk, but also that there's a clear path forward. By tackling these key areas like access control, encryption, backups, password policy, and monitoring the company can massively improve its security and reduce the chance of serious incidents.

As a cybersecurity student, this project was a valuable hands-on experience, and I hope these recommendations help guide meaningful improvements.